AUDIT REPORT · AUD-20261103-33A2

paiement-api — microservice de virements SEPA — RTS 2024/1774 · Politique interne PDS-2 (Banque Kerlann, fictive)

Banque Kerlann (fictive) · paiement-api — microservice de virements SEPA

Lead auditor: **Attest CI**

Owner: **DSI — équipe de développement Paiements**

Date: **2026-11-03 22:48**

Run: **20261103-224808-33a2**

1. Executive summary

OPINION AT TESTING

Unsatisfactory

7 controls tested	**7** findings	**0** findings closed and verified	**7** open findings
0 human approvals	**18** sensitive data items masked in evidence	**0 min 05 s** audit duration	**$0.000 *** measured AI cost



Critical: 1 High: 3 Medium: 3 Low: 0

Key messages

- 7 findings across 7 controls: 1 critical, 3 high, 3 medium.
- 7 findings remain open, with an action plan, an owner and a due date.

2. Scope and method

Engagement	AUD-20261103-33A2
Entity	Banque Kerlann (fictive)
System	paiement-api — microservice de virements SEPA
System criticality	Supporte des fonctions critiques ou importantes (DORA)
Environment	Pré-production de démonstration
Owner	DSI — équipe de développement Paiements
Lead auditor	Attest CI
Date	2026-11-03 22:48
Framework	RTS 2024/1774 — article 16 : acquisition, développement et maintenance des systèmes TIC · Politique interne PDS-2 (Banque Kerlann, fictive) —

	développement sécurisé
Audited target	paiement-api code repository (SEPA transfer microservice)
Work programme	reviewed by an auditor (Attest CI) · runs/studio/20261103-224808-33a2/catalogue.json

In scope

- Code source, configuration et chaîne CI du dépôt
- Jeux de données de test versionnés

Out of scope

- Tests dynamiques (DAST) et tests d'intrusion
- Environnements d'exécution et de production
- Historique git

Method

1. Controls are derived from the framework (DORA, RTS 2024/1774, internal policy); severity is the one set by the policy.
2. Each test is a stored Python script, statically checked before execution (read-only) and run with a read-only service account.
3. The verdict comes from the script, never from the model. A screenshot is reviewed by Muse Spark to corroborate; on disagreement the control is flagged for review.
4. SAM 3.1 delineates the proving rows and the personal data, which is masked before distribution.
5. Every fix goes through a change request approved by the system owner, applied with a dedicated account, logged, then verified by the same test (DORA 9(4)(e)).
6. Every event and piece of evidence is sealed in a hash-chained audit trail (SHA-256).

Limitations

- Tests cover the configuration reported by the system, not the actual strength of authentication factors.
- AI-drafted scripts and catalogue must be reviewed by an auditor before being considered validated.
- Fictitious entity and data: demonstration.

3. Findings overview

REF.	RULE	TITLE	SEVERITY	TESTED	AFTER	STATUS	DUE DATE
F-01	PDS-2.1	Aucun secret en clair dans le code	Critical	Non-compliant		Open	2026-12-03
F-02	PDS-2.2	Vérification TLS des appels sortants	High	Non-compliant		Open	2027-02-01
F-03	PDS-2.3	Hachage robuste des mots de passe	High	Non-compliant		Open	2027-02-01
F-04	PDS-2.6	Données de test synthétiques	High	Non-compliant		Open	2027-02-01
F-05	PDS-2.4	Analyse statique de sécurité en CI	Medium	Non-compliant		Open	2027-05-02
F-06	PDS-2.5	Dépendances épinglées et auditées	Medium	Non-compliant		Open	2027-05-02

F-07	PDS-2.7	Journalisation des authentifications	Medium	Non-compliant	Open	2027-05-02

4. Detailed findings and controls

F-01 PDS-2.1 Aucun secret en clair dans le code

Critical · Non-compliant · Open

CRITERIA

Aucun mot de passe, clé ou jeton n'est écrit en clair dans le code ou la configuration versionnée.

PDS-2.1 · RTS 7(2)

Threshold source: PDS-2.1

> *« Aucun secret (mot de passe, clé, jeton) n'est écrit en clair dans le code source ni dans la configuration versionnée : les secrets viennent d'un coffre ou de variables d'environnement. »*

CONDITION

Observed: `{"matches": [{"line": 6, "path": "app/config.py", "text": "DB_PASSWORD = \"Az••••\" # TODO : déplacer dans le coffre-fort"}, {"line": 7, "path": "app/config.py…`

Expected: `aucun secret littéral`

2 secret(s) en clair dans le code.

RISK

Un secret versionné est exposé à toute personne ayant accès au dépôt et reste dans l'historique git.

RECOMMENDATION

Retirer et révoquer le secret, puis le charger depuis le coffre-fort ou une variable d'environnement.

Due date: 2026-12-03 · Owner: DSI — équipe de développement Paiements

Test procedure: Analyse du dépôt via la passerelle en lecture seule (arborescence, fichiers, recherche).



At testing — The screenshot corroborates the test. Les lignes encadrées correspondent au résultat du test. · 3/3 sensitive data items masked

2026-11-03 22:48:11 · SHA-256 677f1efd61c13982…

F-02 PDS-2.2 Vérification TLS des appels sortants

High · Non-compliant · Open

CRITERIA

Tout appel réseau sortant vérifie le certificat du serveur.

PDS-2.2 · DORA 9(3)(a), RTS 6(2)(a)

Threshold source: PDS-2.2

CONDITION

Observed: `{"matches": [{"line": 18, "path": "app/payments.py", "text": "response = requests.post(PSP_URL, json=payload, timeout=TIMEOUT_S, verify=False)"}]}`

Expected: `aucun verify=False`

1 appel(s) sans vérification TLS.

> *« Tout appel réseau sortant vérifie le certificat TLS du serveur : la vérification n'est jamais désactivée (`verify=False` interdit). »*

RISK

Un attaquant placé sur le réseau peut intercepter ou modifier les ordres de virement.

RECOMMENDATION

Supprimer verify=False et épingler l'autorité de certification du prestataire.

Due date: 2027-02-01 · Owner: DSI — équipe de développement Paiements

Test procedure: Analyse du dépôt via la passerelle en lecture seule (arborescence, fichiers, recherche).



At testing — The screenshot corroborates the test. Les lignes encadrées correspondent au résultat du test.

`2026-11-03 22:48:11 · SHA-256 168099bdf34367c6…`

F-03 PDS-2.3 Hachage robuste des mots de passe

High · Non-compliant · Open

CRITERIA

Les mots de passe sont hachés avec argon2, bcrypt, scrypt ou PBKDF2.

PDS-2.3 · RTS 6(3), RTS 6(4)

Threshold source: PDS-2.3

> *« Les mots de passe sont hachés avec argon2, bcrypt, scrypt ou PBKDF2. MD5 et SHA-1 sont interdits pour tout usage de sécurité. »*

CONDITION

Observed: `{"matches": [{"line": 8, "path": "app/auth.py", "text": "return hashlib.md5(password.encode()).hexdigest()"}]`

Expected: `argon2, bcrypt, scrypt ou PBKDF2`

1 usage(s) de MD5 ou SHA-1.

RISK

En cas de fuite de la base, les mots de passe sont retrouvés en quelques secondes.

RECOMMENDATION

Migrer vers argon2id, avec renouvellement des empreintes à la prochaine connexion.

Due date: 2027-02-01 · Owner: DSI — équipe de développement Paiements

Test procedure: Analyse du dépôt via la passerelle en lecture seule (arborescence, fichiers, recherche).



At testing — The screenshot corroborates the test. Les lignes encadrées correspondent au résultat du test.
2026-11-03 22:48:11 · SHA-256 9b670c1eafd915cb…

F-04 PDS-2.6 Données de test synthétiques

High | Non-compliant | Open

CRITERIA

Les jeux de test sont synthétiques et déclarés comme tels ; aucun export de production.
PDS-2.6 · RTS 16(5)(a)
Threshold source: PDS-2.6

> *« Les données de test sont synthétiques et déclarées comme telles (champ `"synthetic": true`) ; aucun export de production n'est versionné. »*

CONDITION

Observed: `{"files": ["tests/fixtures/clients_export_prod.json"], "matches": [{"path": "tests/fixtures/clients_export_prod.json", "line": 2, "text": "\"export\": \"product…`
Expected: `jeux synthétiques déclarés, aucun export de production`
1 jeu(x) de test non synthétique(s).

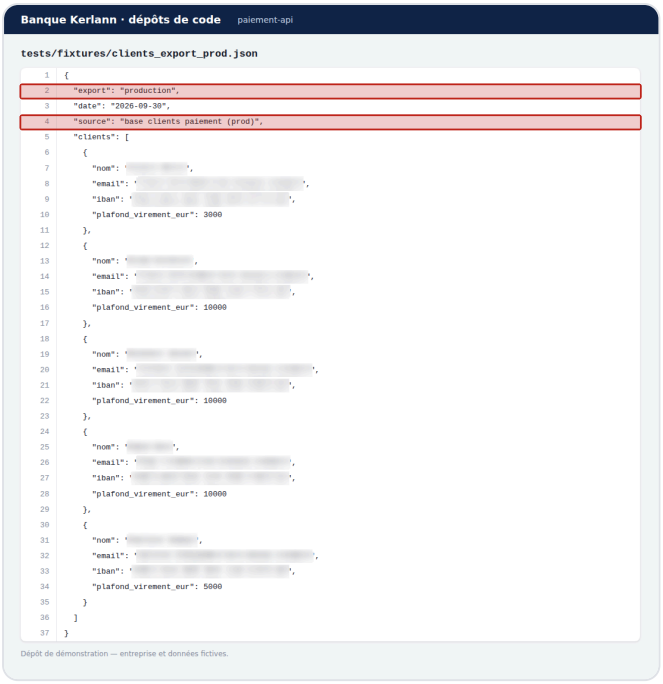
RISK

Des données clients réelles sont exposées hors production.

RECOMMENDATION

Supprimer l'export, purger l'historique git et générer des données synthétiques.
Due date: 2027-02-01 · Owner: DSI — équipe de développement Paiements

Test procedure: Analyse du dépôt via la passerelle en lecture seule (arborescence, fichiers, recherche).



At testing — The screenshot corroborates the test. Les lignes encadrées correspondent au résultat du test. · 15/15 sensitive data items masked

`2026-11-03 22:48:13 · SHA-256 66a5c060e56e2487…`

F-05 PDS-2.4 Analyse statique de sécurité en CI

Medium | Non-compliant | Open

CRITERIA

La chaîne d'intégration continue exécute une analyse statique de sécurité.

PDS-2.4 · RTS 16(3)

Threshold source: PDS-2.4

> *« La chaîne d'intégration continue exécute une analyse statique de sécurité (bandit, semgrep ou CodeQL) à chaque modification. »*

CONDITION

Observed: `{"matches": [{"path": ".github/workflows/ci.yml", "line": 11, "text": "- run: pip install -r requirements.txt pytest"}, {"path": ".github/workflows/ci.yml", "li…`

Expected: `bandit, semgrep ou CodeQL dans la CI`

Aucune analyse statique de sécurité dans la CI.

RISK

Des vulnérabilités atteignent la production sans détection.

RECOMMENDATION

Ajouter une étape bandit ou semgrep bloquante à la CI.

Due date: 2027-05-02 · Owner: DSI — équipe de développement Paiements

Test procedure: Analyse du dépôt via la passerelle en lecture seule (arborescence, fichiers, recherche).



At testing — The screenshot corroborates the test. Les lignes encadrées correspondent au résultat du test.
2026-11-03 22:48:11 · SHA-256 7b53c8bf4ec15d70…

F-06 PDS-2.5 Dépendances épinglées et auditées

Medium | Non-compliant | Open

CRITERIA

Chaque dépendance est épinglée à une version exacte et auditée en CI.
PDS-2.5 · RTS 16(4), RTS 16(8)
Threshold source: PDS-2.5

> *« Les dépendances sont épinglées à une version exacte (`paquet==version`) et auditées en intégration continue (pip-audit ou équivalent). »*

CONDITION

Observed: `{"matches": [{"path": "requirements.txt", "line": 1, "text": "flask"}, {"path": "requirements.txt", "line": 2, "text": "requests>=2.0"}], "dependency_audit_in_c…`
Expected: `paquet==version et pip-audit en CI`
2 dépendance(s) non épinglée(s) ; audit en CI : non.

RISK

Une version vulnérable ou compromise d'une dépendance s'installe sans contrôle.

RECOMMENDATION

Épingler les versions et ajouter pip-audit à la CI.
Due date: 2027-05-02 · Owner: DSI — équipe de développement Paiements

Test procedure: Analyse du dépôt via la passerelle en lecture seule (arborescence, fichiers, recherche).



At testing — The screenshot corroborates the test. Les lignes encadrées correspondent au résultat du test.
2026-11-03 22:48:12 · SHA-256 94071ff0cc3ec301…

F-07 PDS-2.7 Journalisation des authentifications

Medium | Non-compliant | Open

CRITERIA

Les réussites et les échecs d'authentification sont journalisés.

PDS-2.7 · RTS 12(2)(c)(i)

Threshold source: PDS-2.7

> *« Les réussites et les échecs d'authentification sont journalisés par l'application. »*

CONDITION

Observed: `{"matches": [{"path": "app/auth.py", "line": 11, "text": "def login(username: str, password: str) -> bool:"}], "log_calls": 0}`

Expected: `réussites et échecs journalisés`

La fonction de login ne journalise rien.

RISK

Les tentatives de connexion frauduleuses passent inaperçues.

RECOMMENDATION

Journaliser chaque tentative : identifiant, résultat, horodatage.

Due date: 2027-05-02 · Owner: DSI — équipe de développement Paiements

Test procedure: Analyse du dépôt via la passerelle en lecture seule (arborescence, fichiers, recherche).



At testing — The screenshot corroborates the test. Les lignes encadrées correspondent au résultat du test.

2026-11-03 22:48:12 · SHA-256 52576f4c4aef7f78…

Appendices

A. Traceability matrix

REQUIREMENT	RULE	CONTROL	SCRIPT (SHA-256)	RESULT
RTS 7(2)	PDS-2.1	C1 · Aucun secret en clair dans le code	0ac7439a43f9c511 · written by AI for this engagement	Non-compliant
DORA 9(3)(a), RTS 6(2)(a)	PDS-2.2	C2 · Vérification TLS des appels sortants	0345bb97c3bac36c · written by AI for this engagement	Non-compliant
RTS 6(3), RTS 6(4)	PDS-2.3	C3 · Hachage robuste des mots de passe	5f1dc17f7ca22309 · written by AI for this engagement	Non-compliant
RTS 16(3)	PDS-2.4	C4 · Analyse statique de sécurité en CI	d6c17796d9d3a94e · written by AI for this engagement	Non-compliant
RTS 16(4), RTS 16(8)	PDS-2.5	C5 · Dépendances épinglées et auditées	1b16722fb926263e · written by AI for this engagement	Non-compliant
RTS 16(5)(a)	PDS-2.6	C6 · Données de test synthétiques	ce73fc513b7ebfea · written by AI for this engagement	Non-compliant
RTS 12(2)(c)(i)	PDS-2.7	C7 · Journalisation des authentifications	4a9d5a0b8134b7a7 · written by AI for this engagement	Non-compliant

B. Evidence register

FILE			SHA-256
evidence/C1_before.png	C1 · At testing	2026-11-03 22:48:11	677f1efd61c13982913e3cc74210a6ebc77f6ab4ff56b1fef3220704f46b2cb6
evidence/C2_before.png	C2 · At testing	2026-11-03 22:48:11	168099bdf34367c6af05eb21777c45a42a9ffe770d00194506fe75f1de923b8b
evidence/C3_before.png	C3 · At testing	2026-11-03 22:48:11	9b670c1eafd915cb6df201edf42dc67d9cd479c769ad7b5f49bc574e294bd891
evidence/C4_before.png	C4 · At testing	2026-11-03 22:48:11	7b53c8bf4ec15d70db4d0f662dbfcbed5df5f61c644439baf9463e0e95d8b53b
evidence/C5_before.png	C5 · At testing	2026-11-03 22:48:12	94071ff0cc3ec3013b5c4620d989ef9e69def04847069f8c7a03fba625a6574f
evidence/C6_before.png	C6 · At testing	2026-11-03 22:48:13	66a5c060e56e2487eac901cc054bc83e2bc8b557c4795784929fdfcb06dd8de8
evidence/C7_before.png	C7 · At testing	2026-11-03 22:48:12	52576f4c4aef7f780eecc92031a14d86218bd93717f54106b030cd6b1a536c6f

C. AI usage, costs and human oversight

MODEL	CALLS	INPUT TOKENS	OUTPUT TOKENS	IMAGES	COST (USD)

mock	15	22,215	5,206	0	price not published
sam-3.1 (mock)	7	0	0	7	price not published
Total					**0.0000**

Sensitive data (personal data and secrets) in evidence: 18/18 spotted by Muse Spark + SAM, 18/18 masked in the end thanks to the deterministic safety net (page text).

* Mock mode: estimated tokens, indicative cost.

* mock, sam-3.1 (mock): price not published (pricing.toml)

Safeguards

- Scripts: allow-listed imports, no write requests (static analysis before execution).
- Read-only test account: any write would be refused by the system (defence in depth).
- Fixes: allow-listed route and parameters, human approval, separate change account.
- Segregation of duties: the approver cannot be the auditor.

D. Integrity

Audit-trail fingerprint when the report was issued. Verify with `python -m attest verify <folder>`.

`3935a0dca8f6d47cb463375cd124af6ee09ac78c0a0de3b59cd63767bf5e009e`

F. Framework coverage

13 requirements read: 10 tested automatically (7 controls; 3 regulation clauses covered through the policy), 1 left to document review, 1 to interviews, 1 rejected for lack of an exact quote. Attest only covers the first group.

RÉF.	TEXT (VERIFIED QUOTE)	TESTABILITY	CONTROL	
PDS-2.1	« Aucun secret (mot de passe, clé, jeton) n'est écrit en clair dans le code source ni dans la configuration versionnée : les secrets viennent d'un coffre ou de variables d'environnement. »	**tested automatically**	1	Vérifiable par l'interface en lecture seule de la cible.
PDS-2.2	« Tout appel réseau sortant vérifie le certificat TLS du serveur : la vérification n'est jamais désactivée (`verify=False` interdit). »	**tested automatically**	1	Vérifiable par l'interface en lecture seule de la cible.
PDS-2.3	« Les mots de passe sont hachés avec argon2, bcrypt, scrypt ou PBKDF2. MD5 et SHA-1 sont interdits pour tout usage de sécurité. »	**tested automatically**	1	Vérifiable par l'interface en lecture seule de la cible.
PDS-2.4	« La chaîne d'intégration continue exécute une analyse statique de sécurité (bandit, semgrep ou CodeQL) à chaque modification. »	**tested automatically**	1	Vérifiable par l'interface en lecture seule de la cible.

PDS-2.5	« Les dépendances sont épinglées à une version exacte (`paquet==version`) et auditées en intégration continue (pip-audit ou équivalent). »	**tested automatically**	1	Vérifiable par l'interface en lecture seule de la cible.
PDS-2.6	« Les données de test sont synthétiques et déclarées comme telles (champ `"synthetic": true`) ; aucun export de production n'est versionné. »	**tested automatically**	1	Vérifiable par l'interface en lecture seule de la cible.
PDS-2.7	« Les réussites et les échecs d'authentification sont journalisés par l'application. »	**tested automatically**	1	Vérifiable par l'interface en lecture seule de la cible.
	« the procedure shall contain source code reviews covering both static and dynamic testing, including security testing for internet-exposed systems and applications. Financial entities shall: »	**tested automatically**	→ PDS-2.4	Couverte par les contrôles de la politique interne.
	« non-production environments only store anonymised, pseudonymised, or randomised production data; »	**tested automatically**	→ PDS-2.6	Couverte par les contrôles de la politique interne.
	« the procedure shall contain security testing of software packages no later than at the integration phase. »	**tested automatically**	→ PDS-2.5	Couverte par les contrôles de la politique interne.
	« monitor the implementation of that action plan. »	**interview**	0	Nécessite une revue.
	« financial entities shall develop, document and implement a policy governing the acquisition, development, and maintenance of ICT systems. That policy shall: »	**document review**	0	Nécessite une revue.
?	« La banque doit tout chiffrer en quantique. »	**quote not found — rejected**	0	